MITHAQ: A Cryptography-Based Distributed Document Protection and Recovery System for Displaced Persons

Yousef Abuaisheh
Information Security and Ethics
Instructor: Dr. Jehad Hamamreh

***Abstract*—Forced displacement, armed conflict, and natural disasters can separate people from documents needed to establish identity, education, family relationships, and property claims. Ordinary backups may become inaccessible when a phone, password, or local storage site is lost. This paper proposes MITHAQ, a cryptography-based digital document vault designed for confidentiality, tamper detection, geographically redundant storage, and controlled recovery without reliance on a single key custodian. Documents are encrypted on the user's trusted device with AES-256-GCM; SHA-256 provides an optional independently recorded document fingerprint; and a Shamir $(2, 3)$ threshold scheme distributes recovery-key shares among independent custodians. The paper specifies the system architecture, upload and recovery workflows, trust assumptions, adversarial threats, and a reproducible evaluation plan. MITHAQ is a proposed design rather than a deployed service; no measured security or performance results are claimed.**

***Index Terms*—cryptography, digital documents, displaced persons, AES-GCM, SHA-256, Shamir secret sharing, secure recovery**

I. Introduction

People displaced by conflict or disaster may lose paper records and the devices used to access electronic copies. Birth certificates, educational credentials, and property documents may be difficult to replace, particularly when institutions or communications infrastructure are disrupted. Storing unencrypted scans online exposes sensitive information, while keeping a single backup or recovery secret creates a single point of failure.

MITHAQ is proposed as a secure document preservation and recovery system for refugees and displaced families. Its objective is to allow a legitimate owner to retrieve a confidential digital copy even after losing a primary device, provided sufficient independent storage and recovery services remain available. The system does not replace official registries, validate a document's legal status, or guarantee that a scan is authentic.

The main design contributions are: (i) client-side authenticated encryption; (ii) independent geographically separated encrypted replicas; (iii) threshold recovery-key custody; and (iv) a recovery protocol that requires identity and authorization checks before shares are released. These are design goals to be evaluated, not experimentally established outcomes.

II. System Description

A. Actors and trust boundaries

The system contains a document owner, a trusted client application, encrypted storage providers, three independent key-share custodians, and an identity-verification process. The storage providers receive ciphertext only. A custodian receives one share and cannot individually reconstruct the recovery key. Custodians should operate under independent administrative control and, where feasible, separate failure domains.

Humanitarian or identity-support organizations may be considered as potential verification partners, but no participation or agreement with any organization is assumed. Identity verification and technical key custody are distinct responsibilities.

B. Document encryption and integrity

For each document, the trusted client generates a fresh 256-bit document-encryption key K_D and a unique 96-bit nonce N. Using AES-GCM, it computes

$$(C, T) = \text{AES-GCM-Enc}(K_D, N, P, A), \qquad (1)$$

where P is the plaintext document, A is authenticated metadata, C is ciphertext, and T is the authentication tag. Nonces must never be reused with the same key. The client stores the ciphertext, nonce, tag, and necessary nonsecret metadata as an encrypted document package.

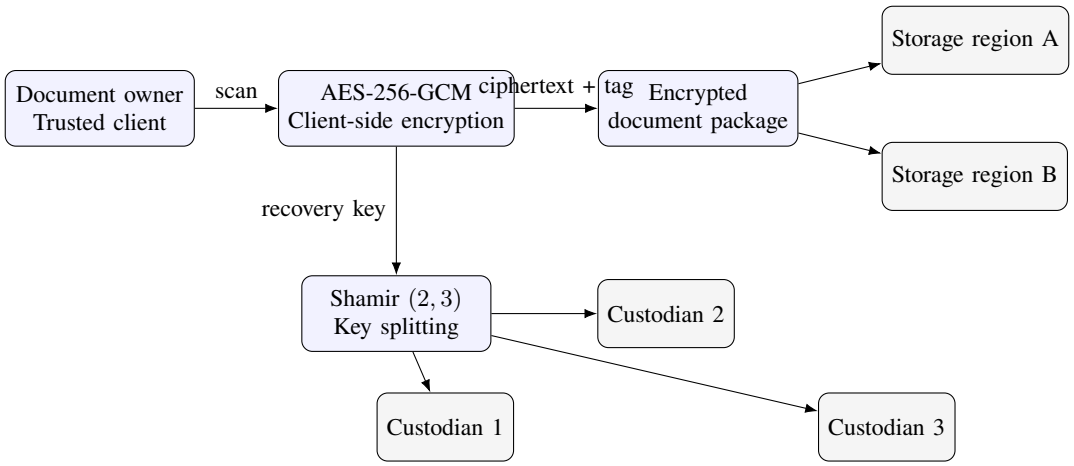


Fig. 1. Proposed MITHAQ architecture. Storage providers hold encrypted copies; independent custodians hold separate recovery-key shares. Diagram illustrates logical separation, not existing organizational partnerships.

The document key is wrapped under a separately generated recovery key K_R using authenticated encryption; only the wrapped document key is stored with the package.

An optional document fingerprint is $h = \mathrm{SHA\text{-}256}(P)$. The fingerprint must be protected as authenticated metadata or maintained in a trusted record: an untrusted party could otherwise replace both a file and its hash. AES-GCM's tag already detects unauthorized modification of the encrypted package; SHA-256 is useful as an independent reference fingerprint, not a substitute for authenticated encryption or a digital signature.

C. Threshold key sharing

To avoid placing K_R under a single custodian, the client applies Shamir's secret sharing over a suitable finite field. For a two-out-of-three policy, it samples a random coefficient a and forms

$$f(x) = K_R + ax \pmod{p}, \qquad S_i = (i, f(i)),\ i \in \{1, 2, 3\}. \tag{2}$$

Here K_R is represented as a valid field element or encoded using a suitable vetted secret-sharing implementation. Each custodian receives one share S_i over an authenticated secure channel. Any two valid shares can reconstruct K_R by Lagrange interpolation, while a single share reveals no information about the secret under the scheme's assumptions [1]. The two-share threshold improves availability but means two colluding custodians can recover the key; therefore custody independence and share-release controls remain essential.

III. Proposed Operational Protocol

A. Enrollment and upload

The owner enrolls through a trusted client and establishes a recovery policy. For each scanned document, the client generates keys, encrypts locally, optionally computes the document fingerprint, wraps the document key, and sends the encrypted package to at least two storage locations. The client creates three shares of the recovery key and securely delivers one to each independent custodian. A protected manifest associates a document identifier with storage replicas and the applicable recovery policy. Sensitive plaintext and unwrapped keys should not be logged or retained unnecessarily.

B. Recovery after device loss

A recovery request begins with independent identity and authorization checks, using a process designed for people who may lack their original device or credentials. After approval, two separate custodians authorize release of their shares through authenticated, audited channels. Shares should be reconstructed on a newly trusted user-controlled device rather than at a central service. The client recovers K_R, unwraps K_D, downloads a valid encrypted replica, and performs AES-GCM authenticated decryption. If authentication fails, the package is rejected. Temporary key material and released shares are erased where the platform permits.

IV. Security Analysis and Limitations

A. Threat model

The design considers an attacker who steals a device, accesses one encrypted storage provider, intercepts network traffic, tampers with a stored encrypted package,

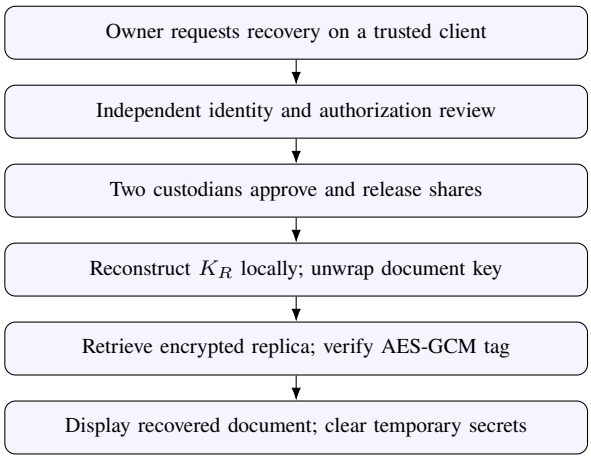


Fig. 2. Proposed recovery workflow. Authorization is required before share release; threshold cryptography alone does not verify identity.

or compromises one key-share custodian. Authenticated client-to-service communication and correctly implemented AES-GCM limit exposure to ciphertext theft and modification. One compromised custodian cannot reconstruct the recovery key alone. Geographically separated replicas reduce the impact of an isolated storage outage, but do not guarantee availability during widespread infrastructure failure.

The design does not protect against every threat. A compromised client may expose plaintext or keys before encryption or after decryption. Two colluding custodians can reconstruct the recovery key. Identity fraud or coercion could defeat recovery authorization. SHA-256 does not establish who issued a document, and scanned copies do not automatically carry legal validity. Digital signatures from issuing authorities could support provenance where such infrastructure exists.

B. Key management and privacy

Recovery keys should be independently generated with a cryptographically secure random generator, and shares must be authenticated and protected in transit and at rest. Share rotation, replacement of an unavailable custodian, and revocation after a suspected compromise require a carefully designed re-sharing procedure. Recovery approval should use independent factors, rate limits, audit trails, and an appeal process that does not unnecessarily disclose sensitive refugee information. Cross-border storage introduces privacy, jurisdiction, retention, and data-transfer obligations that require legal review before deployment.

TABLE I
PROPOSED MECHANISMS AND RESIDUAL RISKS

Goal	Proposed mechanism	Remaining limitation
Confidentiality	AES-256-GCM on client	Compromised endpoint
Integrity	GCM tag; optional SHA-256	Hash alone not provenance
Key recovery	Shamir 2-of-3 shares	Two-custodian collusion
Availability	Separate encrypted replicas	Correlated outages
Access control	Identity review and approval	Impersonation risk

V. Evaluation Plan

This paper specifies a design; implementation and empirical evaluation remain future work. A prototype could use a vetted cryptographic library and synthetic, non-sensitive documents. Its evaluation should include the following tests:

1) *Correctness:* encrypt and decrypt files of multiple sizes and verify byte-for-byte equality.
2) *Tamper detection:* modify ciphertext, nonce, tag, and authenticated metadata separately; require decryption failure.
3) *Threshold behavior:* demonstrate successful reconstruction with any two shares and failure to reconstruct with one share.
4) *Fault tolerance:* disable one storage replica or one custodian and test whether authorized recovery remains possible.
5) *Performance:* measure encryption, decryption, upload, download, and recovery latency for representative file sizes.
6) *Abuse resistance:* test rejected unauthorized requests, audit records, and rate limiting without using real personal documents.

Performance results, security claims, and operational feasibility should be reported only after prototype implementation and documented testing. The proposed 2-of-3 threshold is a configurable design choice rather than a proof of organizational trust.

VI. Conclusion

MITHAQ proposes a cryptographic approach to protecting and recovering digital copies of critical documents for displaced persons. Client-side AES-256-GCM provides confidentiality and authenticated decryption,

TABLE II
PLANNED EVALUATION MATRIX (NO MEASURED RESULTS)

Test condition	Expected acceptance criterion
Valid key and package	Exact plaintext recovery
Modified GCM ciphertext/tag	Authentication failure
One of three shares	No secret reconstruction
Any two valid shares	Recovery key reconstructed
One storage region unavailable	Retrieval from remaining replica
Unapproved recovery request	No share release

SHA-256 can support independently protected fingerprints, and Shamir's threshold sharing enables recovery without a single key custodian. Distributed encrypted replicas can improve resilience to localized failures. Real-world deployment nevertheless depends on reliable identity verification, independent custodians, endpoint security, legal safeguards, and usability under difficult conditions. The next step is to implement and evaluate a prototype using synthetic documents and explicit security test cases.

REFERENCES

[1] A. Shamir, "How to share a secret," *Communications of the ACM*, vol. 22, no. 11, pp. 612–613, 1979.

[2] M. Dworkin, "Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM) and GMAC," NIST SP 800-38D, 2007.

[3] NIST, "Secure Hash Standard (SHS)," FIPS PUB 180-4, 2015.

[4] E. Barker, "Recommendation for Key Management: Part 1 – General," NIST SP 800-57 Part 1 Rev. 5, 2020.

[5] OWASP Foundation, "Cryptographic Storage Cheat Sheet," OWASP Cheat Sheet Series.